Historia de Usuario 16

HU-16	**TÍTULO:** Acceso > Inicio de sesión > Entrar con usuario y recuperar la contraseña	M7 · Req. 16 · 5 pts

Como usuario del sistema
Quiero entrar con mi usuario y mi contraseña, definir mi propia contraseña en el primer ingreso y poder recuperarla cuando la olvido
Para acceder sin depender de un correo que no siempre tengo, sin quedar fuera cuando olvido la clave y sin que otra persona pueda entrar probando contraseñas

Descripción

El pliego pide que solo el personal autorizado opere el sistema. En el primer sprint se entraba con el correo (HU-01); muchos docentes no tienen un correo institucional a mano y los auxiliares casi nunca. Esta historia cambia el identificador: se entra con un usuario del tipo «nombre.apellido» y el correo pasa a ser un dato de contacto, opcional, que solo sirve para recibir avisos y el enlace de recuperación. No hay registro público: las cuentas las crea el administrador.

La pantalla de inicio pide «Usuario» y «Contraseña» y tiene tres salidas: «Iniciar sesión», «Recuperar contraseña» y «Entrar con código de aula». Esta última es la entrada del ayudante sin cuenta y no es parte de esta historia: se resuelve en HU-18. Quien entra va a la primera vista que su rol le permite; los tres roles de inicio son administrador, docente y auxiliar.

Una cuenta nace con una contraseña temporal que vale 72 horas. Quien entra con ella no puede usar nada más hasta definir la propia en «Contraseña nueva»: al menos 10 caracteres, mayúscula, minúscula y número, distinta de la temporal. La contraseña propia no vence. Si la temporal venció, el sistema lo dice y hay que pedir otra al administrador.

Cinco intentos fallidos seguidos bloquean la cuenta 15 minutos. Antes de llegar a eso el sistema avisa cuántos intentos quedan, y durante el bloqueo dice cuántos minutos faltan. El bloqueo no se alarga por seguir intentando y se levanta solo, o antes si la contraseña se restablece.

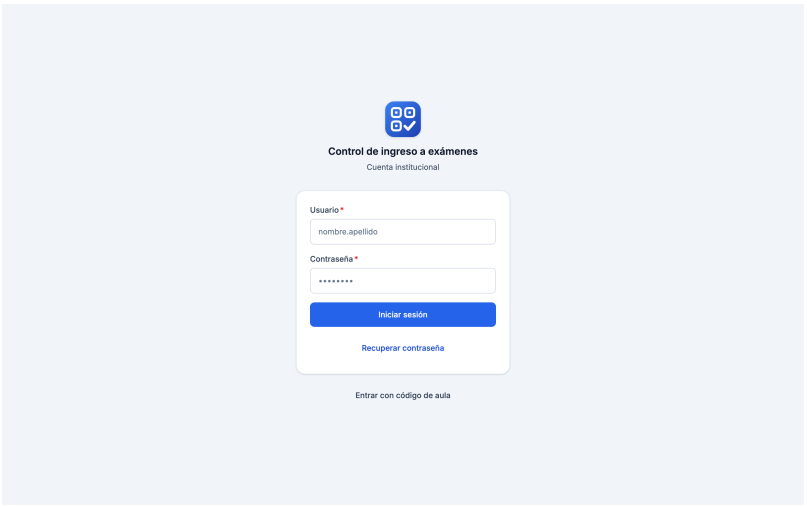
La recuperación va por correo: el usuario escribe su nombre de usuario y, si la cuenta tiene un correo registrado, recibe un enlace de un solo uso que vence a los 60 minutos. El sistema responde lo mismo exista o no la cuenta, para no revelar qué usuarios hay. Quien no tiene correo no recibe nada: su contraseña la restablece el administrador desde Usuarios (HU-15), con una temporal nueva.

La sesión se cierra con «Cerrar sesión» o sola, tras 120 minutos sin actividad. Mientras dura, el armazón muestra el nombre de la cuenta y su rol.

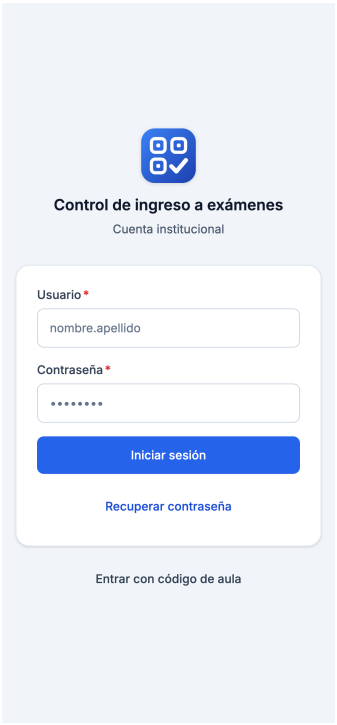
La vista depende de que la cuenta exista: las de los docentes se activan en HU-12 y las demás se crean en HU-15, que también emite las contraseñas temporales y bloquea o desbloquea cuentas. De ella dependen todas las vistas del sistema, que exigen sesión y el permiso del rol (HU-15). Cada ingreso, intento fallido, cierre, cambio y restablecimiento queda asentado en la bitácora (HU-07), nunca con la contraseña.

Mockups

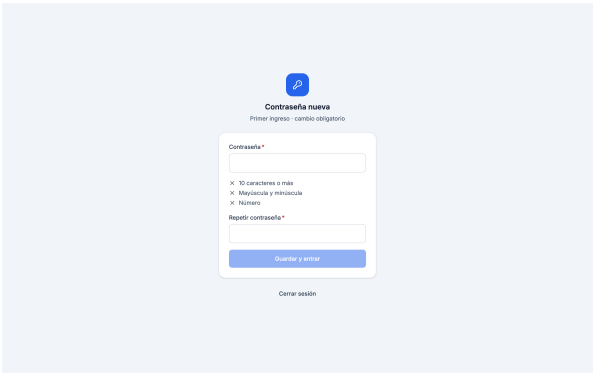
Escritorio

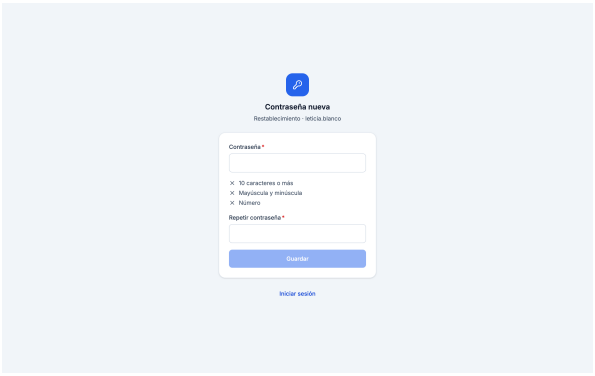


Móvil



Otras pantallas de la historia





Criterios de aceptación

1. Dado que una persona abre el sistema sin sesión, Cuando se muestra el inicio, Entonces ve «Control de ingreso a exámenes · Cuenta institucional», los campos «Usuario» y «Contraseña», el botón «Iniciar sesión» y los enlaces «Recuperar contraseña» y «Entrar con código de aula» (HU-18); no hay campo de correo ni registro público.
2. Dado que la cuenta está activa y la contraseña es correcta, Cuando el usuario pulsa «Iniciar sesión», Entonces el sistema abre la sesión y lo lleva a la primera vista de su rol; el usuario no distingue mayúsculas y una cuenta sin correo entra igual.
3. Dado que alguien escribe su correo en el campo «Usuario», Cuando intenta entrar, Entonces el

sistema no lo acepta como identificador y señala el campo con «Solo letras, números, puntos y guiones»; el usuario admite hasta 60 caracteres.

4. Dado que falta el usuario o la contraseña, Cuando se pulsa «Iniciar sesión», Entonces el sistema no consulta al servidor y señala el campo con «Obligatorio».
5. Dado que la contraseña no es correcta y la cuenta existe, Cuando se intenta entrar, Entonces el sistema muestra «Usuario o contraseña incorrectos» seguido de los intentos que quedan («4 intentos restantes» … «1 intento restante»); si la cuenta no existe muestra el mismo texto sin la cifra.
6. Dado que la cuenta suma cinco intentos fallidos seguidos, Cuando ocurre el quinto, Entonces queda bloqueada 15 minutos y el sistema muestra «Cuenta bloqueada · 15 minutos»; durante el bloqueo rechaza también la contraseña correcta, indica los minutos que faltan y no alarga el plazo.
7. Dado que el bloqueo venció, o que el usuario acertó antes del quinto intento, Cuando entra con su contraseña, Entonces el sistema lo deja pasar y el contador de intentos vuelve a cero.
8. Dado que el administrador desactivó la cuenta, Cuando su titular intenta entrar con cualquier contraseña, Entonces el sistema muestra «Cuenta bloqueada» sin minutos, y si tenía una sesión abierta la pierde en la siguiente consulta.
9. Dado que la cuenta tiene una contraseña temporal vigente, Cuando el usuario entra con ella, Entonces el sistema lo lleva a «Contraseña nueva · Primer ingreso · cambio obligatorio» y, hasta que la cambie, rechaza cualquier otra operación; solo puede guardar la nueva o «Cerrar sesión».
10. Dado que el usuario escribe su contraseña nueva, Cuando teclea, Entonces ve cómo se cumplen las reglas «10 caracteres o más», «Mayúscula y minúscula» y «Número», la repetición distinta se señala con «No coincide» y «Guardar y entrar» solo se habilita con todo cumplido; no se pide la contraseña actual.
11. Dado que la contraseña nueva repite la temporal, Cuando se guarda, Entonces el sistema la rechaza con su mensaje bajo el campo; si es válida, la cuenta queda con contraseña propia, que no vence, y el usuario entra a la vista de su rol.
12. Dado que pasaron 72 horas desde que se emitió la contraseña temporal, Cuando el usuario entra con ella, Entonces el sistema no abre la sesión y muestra «Contraseña temporal vencida», sin sumar un intento fallido; la cuenta vuelve a servir cuando el administrador emite otra temporal (HU-15).
13. Dado que el usuario olvidó su contraseña, Cuando pulsa «Recuperar contraseña», Entonces se abre un diálogo con su usuario ya escrito y los botones «Cancelar» y «Enviar enlace»; sin usuario no se envía y el campo dice «Obligatorio».
14. Dado que la cuenta tiene un correo registrado, Cuando se pulsa «Enviar enlace», Entonces el sistema envía a ese correo un enlace de un solo uso y avisa «Enlace enviado al correo de» seguido del usuario; si la cuenta no existe, está desactivada o no tiene correo responde lo mismo y no envía nada.
15. Dado que el usuario abre el enlace del correo, Cuando escribe y repite una contraseña que cumple las reglas y pulsa «Guardar», Entonces el sistema la cambia, levanta el bloqueo por intentos si lo había, vuelve al inicio y avisa «Contraseña actualizada».
16. Dado que el enlace ya se usó, pasó de 60 minutos, está incompleto o fue alterado, Cuando se abre o se intenta guardar, Entonces el sistema no cambia la contraseña y muestra «Enlace no válido o vencido» con el enlace «Iniciar sesión».
17. Dado que el usuario tiene la sesión abierta, Cuando navega, Entonces el armazón muestra su

nombre y su rol; «Cerrar sesión» la termina y vuelve al inicio, y tras 120 minutos sin actividad el sistema la da por cerrada y vuelve a pedir el acceso.

18. Dado que se inicia o se cierra una sesión, falla un intento, se cambia la contraseña, se pide el enlace o se restablece, Cuando la operación se completa, Entonces queda asentada en la bitácora con su cuenta —el intento fallido, con el usuario tecleado— y nunca con la contraseña; en un dispositivo móvil las tres pantallas se adaptan de forma completamente responsiva.

Pruebas automatizadas

- `AuthenticationControllerTest`: ingreso con usuario, sin distinguir mayúsculas, cuenta sin correo, correo rechazado como identificador, campos obligatorios, sesión regenerada y cierre explícito (criterios 1 a 4 y 17).
- `LoginSecurityTest` y `AuthenticationControllerTest`: intentos restantes, cuenta inexistente sin cifra, bloqueo al quinto intento, minutos que faltan, contraseña correcta rechazada sin alargar el bloqueo, ingreso tras el vencimiento, contador en cero y cuenta desactivada (criterios 5 a 8).
- `ContrasenaTemporalTest`: temporal que vence a las 72 horas, primer ingreso que exige el cambio, sin pedir la actual, temporal que no se repite como propia, temporal vencida y contraseña propia que no vence (criterios 9, 11 y 12).
- `CambioContrasenaTest`: regla de 10 caracteres con mayúscula, minúscula y número, confirmación, resto del sistema cerrado hasta el cambio y asiento en la bitácora (criterios 9 a 11 y 18).
- `RestablecimientoContrasenaTest`: enlace enviado a la cuenta con correo, misma respuesta sin cuenta, sin correo o desactivada, restablecimiento con enlace válido, enlace de un solo uso, vencido o falsificado, desbloqueo y asientos (criterios 13 a 16 y 18).
- `ContrasenaTemporalTest` y `RestablecerTemporalTest`: la temporal nueva que emite el administrador reemplaza a la vencida y levanta el bloqueo por intentos (criterio 12).
- `SesionTest` y `SessionInactivityTest`: nombre, rol y permisos de la sesión, cuenta bloqueada que pierde la sesión abierta, vencimiento por inactividad y sesión cerrada que no se reutiliza (criterios 8 y 17).
- `BitacoraSesionTest` y `AuthenticationHardeningTest`: asiento del ingreso, del intento fallido y del cierre, sin la contraseña en la bitácora ni en texto plano en la base (criterio 18).
- `Login.test.jsx`: campos y enlaces del inicio, validación antes de llamar al servidor, intentos restantes en singular y plural, bloqueo con y sin minutos, temporal vencida, paso al primer ingreso y diálogo de recuperación (criterios 1 a 9 y 12 a 14).
- `PrimerIngreso.test.jsx` y `RestablecerContrasena.test.jsx`: reglas a la vista, repetición que no coincide, rechazo del servidor bajo el campo, cierre de sesión, envío del usuario y del enlace, y enlace no válido o vencido (criterios 9 a 11, 15 y 16).